

Cybersecurity Business Plan

developed for

PowerTools Corporation

on

December 21, 2024

<Company LOGO HERE>

Developed by Smruti Ranjan Dash, Director of Cybersecurity

Table of Contents

Company Introduction	4
Executive Overview.....	5
ISO 27001 and ISO 27002	5
Security-Relevant Organizational Issues.....	6
Cybersecurity Strategy.....	6
Areas of Focus.....	6
Company-Specific Goals	7
Goal Timelines and Success Metrics.....	8
Long-Term Strategies.....	8
Applicable Legal and Regulatory Requirements.....	9
Roles and Responsibilities	9
Board of Directors.....	9
CEO.....	9
Chief Counsel (Legal)	9
CISO.....	10
Director of Cybersecurity.....	10
CIO.....	10
Audit & Compliance Officer	10
Chief Risk Officer.....	10
IAM Manager	10
IT Operations	10
Security Incident Response/	10
Human Resources	11
Results of a Security Controls Gap Assessment.....	12
Summary Results Overview	12
Risk Assessment Results	22
Summary of Findings	22
Classification Scheme	23
Asset Inventory	24
Security Impact Analysis	24
Threat Exposure (Risk) Ratings	25
Evaluation of Existing Safeguards and Residual Risk Ratings	25

Detailed Findings	26
Risk Treatment Strategy	28
Maintaining the Risk Register	29
Concluding Remarks	29
Document History	30
References	31
List of Attachments.....	32

Company Introduction

Power Tools Corp is a global leader in manufacturing and distributing innovative, high-performance power tools and equipment for both professional and consumer markets. Headquartered in Calgary, Canada, the company has built a reputation for delivering durable, reliable, and technologically advanced solutions tailored to the evolving needs of its customers.

With a commitment to quality, innovation, and sustainability, Power Tools Corp leverages cutting-edge technology, including IoT-enabled tools and smart manufacturing practices, to maintain its competitive edge. The company serves industries such as construction, woodworking, automotive, and home improvement, providing solutions that empower professionals and enthusiasts alike.

Executive Overview

As part of an effort to improve their security posture, PowerTools Corporation has recently established a Director of Cybersecurity position reporting to the CISO. PowerTools Corporation is devoted to protecting its personnel, clients, investors as well as its technological, corporate, and information assets from the threats posed by its rapidly evolving business landscape.

Smruti Ranjan Dash was appointed to the Director of Cybersecurity position the first week of December 2024. He was assigned to develop a Cybersecurity Business Plan that would guide PowerTools Corporation to compliance with the ISO 27002 Code of Practice for Information Security Management.

The purpose of this project is to Develop and Govern a Strong Security Culture, Manage Risk in the Language Business, establish a Control Baseline, Simplify and Rationalize IT & Security, Control Access with Minimal Drag on the Business, Institute Resilient Detection, Response, and Recovery.

ISO 27001 and ISO 27002

1. The organization has a structured plan for improving security culture, stakeholder engagement, and governance.
2. Risk management and control baselines are being actively reviewed and updated.
3. Progress on access management, incident response, and IoT monitoring demonstrates alignment with ISO 27001/27002 requirements.
4. Access control rationalization and SSO implementation are in progress, aligning with ISO 27002's guidance on identity and access management.
5. Enhance training programs for stakeholders to improve awareness of evolving IoT threats.
6. Complete planned objectives within the defined timelines and continue monitoring metrics for each focus area.
7. Regularly evaluate the ISMS for compliance with ISO 27001 Clauses 9 (Performance Evaluation) and 10 (Improvement).
8. Achieve 100% SIEM implementation and conduct 5 tabletop exercises within 90 days.

ISO 27001 Certification has a very rigid audit process, all target security controls need to be 100% in compliance with ISO standards. An **ISO 27002 Compliance Assessment** uses the same set of standards and control testing however the target compliance baseline is set for 85% compliance. Hence the baseline for PowerTool's compliance is targeted to 85%.

Security-Relevant Organizational Issues

The following main security-related organizational issues have been identified at PowerTools Corporation and are

1. Security related role gaps: Critical security roles are undefined or unfilled, leading to incident resolution SLA misses and weakening disaster recovery efforts.
2. Asset ownership: Asset ownership responsibilities are unclear, and IT staff lack a pathway to transition into security roles.
3. Baseline gaps: Control baselines are outdated, leaving significant security gaps unaddressed.
4. Security tools not integrated: SIEM not onboarded for IoT devices, the monitoring should be integrated with endpoints.
5. SSO Inefficiency: SSO processes are inconsistent, causing access management challenges and inefficiencies.
6. Incident response: Incident response plans are outdated and no tabletop exercises, reducing preparedness for modern threats.

Cybersecurity Strategy

Areas of Focus

¹This Cybersecurity Business Plan will address the following six priority focus areas to remediate the issues outlined in the previous section [3]:

1. Security-related business role gaps, fulfillment & Disaster recovery planning & review.
2. Asset owner identification & devise a program to identify IT champions to be promoted to work in security program.
3. Baseline review & Gap assessment.
4. Security tools consolidation/integration.
5. SSO processes streamlined.
6. Tabletop exercises & incident response plan updates.

¹ The priority focus areas outlined here are taken from Dan Blum's 2020 Rational Cybersecurity for Business Textbook. It is referenced at [3] in the References section.

Company-Specific Goals

²The table below outlines goals specific to PowerTools Corporation as they related to each of the above priority focus are

Priority Focus Area	PowerTools Corporation Goal
Develop and Govern a Strong Security Culture	Address security-related business role gaps by defining and fulfilling critical security roles. Improve disaster recovery planning and ensure regular reviews for effectiveness.
Manage Risk in the Language Business	Identify asset owners and devise a program to promote IT champions into cybersecurity roles, strengthening accountability and risk management.
Establish a Control Baseline	Conduct a baseline review and perform a gap assessment to align controls with modern cybersecurity standards and address unmitigated risks.
Simplify and Rationalize IT & Security	Consolidate and integrate overlapping security tools to streamline operations, reduce costs, and enhance efficiency.
Control Access with Minimal Drag on the Business	Streamline SSO processes to simplify access management, enhance user experience, and improve security.
Institute Resilient Detection, Response, and Recovery	Update and test incident response plans through tabletop exercises to ensure preparedness for modern threats like ransomware and IoT-specific attacks.

² Many of the goals listed here are adapted from Dan Blum's 2020 Rational Cybersecurity for Business Textbook. It is referenced at [3] in the References section.

Goal Timelines and Success Metrics

The table below outlines high-level steps that shall be taken in the defined timeframes to achieve the goals outlined above

Priority Focus Area	Goal	Timeline (Days)	Responsible Team/Stakeholders	Status
Develop and Govern a Strong Security Culture	Define and fulfill critical security roles. Improve disaster recovery planning and conduct regular reviews.	0-90	HR, CISO, Disaster Recovery Team	In Progress
Manage Risk in the Language Business	Identify asset owners and implement a program to promote IT champions into cybersecurity roles.	0-120	Asset Management Team, IT Leaders	Planned
Establish a Control Baseline	Perform baseline review and gap assessment to align with modern standards and mitigate risks.	30-90	Compliance, IT Security Team	Planned
Simplify and Rationalize IT & Security	Consolidate and integrate redundant security tools to improve efficiency and reduce operational costs.	0-180	IT Operations, Vendor Management	Planned
Control Access with Minimal Drag on the Business	Streamline SSO processes to enhance user experience, reduce manual tasks, and improve access control.	0-90	IAM Team, IT Security	In Progress
Institute Resilient Detection, Response, and Recovery	Update and test incident response plans through tabletop exercises to improve preparedness for threats like ransomware and IoT-specific breaches.	0-120	Incident Response Team, CISO	Planned

Long-Term Strategies

The goals outlined in the sections above align with PowerTools Corporation's long-term strategy to strengthen its cybersecurity posture by addressing security-related business role gaps, improving disaster recovery planning, promoting IT champions into cybersecurity roles, conducting baseline reviews and gap assessments, consolidating and integrating security tools, streamlining SSO processes, and enhancing incident response capabilities through regular tabletop exercises and plan updates. These initiatives are time-tracked and assigned to specific teams to ensure systematic progress toward building a resilient and secure organizational framework.

Applicable Legal and Regulatory Requirements

Powertools Corp must abide by the following legal regulations:

- **PIPEDA:** Protect personal data, report breaches.
- **Provincial Privacy Laws:** Quebec, BC, Alberta-specific regulations.
- **CCPSA:** Ensure product safety, report issues.
- **CSA/ISO Certification:** Compliance with industry standards.
- **OHS Regulations:** Provincial safety compliance.
- **CUSMA/USMCA:** Trade with U.S. and Mexico.
- **NRCan:** Meet energy efficiency requirements.

Roles and Responsibilities

³The development of an effective Cybersecurity Business Program requires security-related roles and responsibilities to be clearly defined, and the top business leaders are responsible for “owning” information risks as part of enterprise risk management, overseeing the operations of security leadership, and setting cybersecurity budgets and strategic priorities for their areas.

Board of Directors

The Board of Directors shall recognize that cybersecurity is “an enterprise-wide risk management issue” [3] and not just an IT issue. The Board of Directors shall have adequate access to cybersecurity expertise, and discussions about cyber-risk management should be given regular and adequate time on board meeting agendas.

Directors should set the expectations that management will establish a enterprise-wide cyber risk management framework with adequate staffing and budget”

CEO

The Chief Executive Officer (CEO) shall remain accountable to the Board and public for any serious failure. CEOs must also address cybersecurity-related objectives with their direct reports and ensure the right people are in place and managing cybersecurity.

Chief Counsel (Legal)

The Chief Counsel (Legal) shall support PowerTools Corporation’s cybersecurity program by approving or managing security-related content contracts with employees, third parties such as vendors and contractors, and the participants in mergers, acquisitions, and joint ventures. It has input and approval on the following security-related functions:

- Audit, compliance, and HR-related security issues
- Breach investigations, response, and notifications
- Security policies

³ Many of the roles and responsibilities listed here are adapted from Dan Blum’s 2020 Rational Cybersecurity for Business Textbook. It is referenced at [3] in the References section

- Estimating liability risk

CISO

The CISO shall oversee and be accountable for all PowerTools Corporation's cybersecurity program. The CISO operates and communicates as the champion for cybersecurity. He or she should continuously educate executives on what they need to know about cybersecurity from the business perspective but always frame the communication in terms of business risks, impacts, or opportunities.

Director of Cybersecurity

The Director of Cybersecurity shall report directly to the CISO and oversee the implementation of cybersecurity strategies, ensure alignment with business objectives, manage security-related projects, and lead efforts to safeguard PowerTools Corporation's systems, data, and IoT-enabled products against evolving threats.

CIO

The CIO shall oversee PowerTools Corporation's IT environment and ensure the alignment of IT strategies with business goals, manage technology infrastructure, drive digital transformation initiatives, and collaborate with the cybersecurity team to mitigate risks and secure enterprise systems.

Audit & Compliance Officer

The Audit and Compliance Officer shall ensure PowerTools Corporation's adherence to regulatory requirements, conduct internal audits to assess compliance with policies and standards, identify areas of non-compliance, and maintain accountability.

Chief Risk Officer

The Chief Risk Officer shall oversee PowerTools Corporation's risk management framework, identify and assess enterprise-wide risks, develop mitigation strategies, and ensure alignment with business objectives while fostering a culture of risk awareness and resilience across the organization.

IAM Manager

The Identity and Access Management (IAM) Manager shall oversee PowerTools Corporation's access control systems, enforce role-based access policies, manage SSO implementation.

IT Operations

IT Operations shall manage PowerTools Corporation's IT infrastructure, ensure the availability and performance of systems and networks, oversee routine maintenance and patch management.

Security Incident Response

The Security Incident Response Leader shall coordinate PowerTools Corporation's response to cybersecurity incidents, lead investigations, manage containment and recovery efforts, document incident findings, implement lessons learned to strengthen the organization's security posture, and conduct regular tabletop exercises with internal teams and external partners to test and refine incident response plans.

Human Resources

Human Resources (HR) shall conduct thorough background checks for all employees and contractors, ensure compliance with security policies during the hiring process, ensure cybersecurity awareness trainings are being completed by employees every quarter, and collaborate with the cybersecurity team to address any personnel-related security concerns.

Results of a Security Controls Gap Assessment

Summary Results Overview

As part of PowerTools Corporation's (PowerTools) strategic efforts to enhance its cybersecurity posture and align with international best practices, an ISO 27002 Compliance Readiness Assessment was conducted. This initiative demonstrates the organization's commitment to safeguarding its data, systems, and processes against evolving security threats while meeting regulatory and business requirements.

This report presents findings and recommendations from the assessment. It evaluates PowerTools' existing security controls against the ISO 27002 standards and provides practical guidance for achieving compliance.

The assessment revealed that PowerTools has achieved a compliance rate of 70%, with 20% of controls requiring improvement and 10% deemed non-existent. These gaps highlight the need for structured remediation efforts to achieve the desired compliance level.

A. Security Governance Improvement

Objective

To enhance PowerTools Corporation's security governance by improving communication, aligning business needs with security objectives, and addressing critical gaps identified in current processes.

Goals and Deliverables

1. Increase CISO and Security Team Communication with Stakeholders

- **Action Items:**
 - Hold monthly security update meetings.
 - Focus specifically on IoT security and compliance.
- **Deliverables:**
 - Meeting schedules shared with all stakeholders.
 - Monthly presentations on IoT security initiatives and progress.
 - Stakeholder feedback on updates.
- **Timeline:** Monthly, starting January 2025.
- **Status:** In Progress.

2. Define and Secure Approval for the Security Charter

- **Action Items:**
 - Create or revisit the Security Charter.
 - Secure business buy-in for a Definition of Security aligned with business needs.
 - Involve CTO, CIO, and R&D teams to align on IoT-specific security priorities.
- **Deliverables:**
 - Updated Security Charter document.
 - Approved Definition of Security.
- **Timeline:** Completion by Q2 2025.
- **Status:** Planned.

3. Address Security-Related Role Gaps

- **Action Items:**
 - Review Table 2-2 from Chapter 2 for potential security-related roles.
 - Communicate with stakeholders to understand and address role gaps.
- **Deliverables:**
 - List of critical unfulfilled security roles.
 - Action plan for role fulfillment.
- **Timeline:** Completion by Q3 2025.
- **Status:** Pending.

4. Strengthen Security Steering Committee Effectiveness

- **Action Items:**
 - Review past 6-12 months of Security Steering Committee meeting records.
 - Analyze meeting strengths and weaknesses.
 - Propose actionable improvements, with a focus on addressing disaster recovery gaps.

- **Deliverables:**
 - Committee improvement plan.
 - Disaster recovery recommendations.
- **Timeline:** Completion by December 2024.
- **Status:** Completed.

5. Assess and Align Security Budgets and Funding

- **Action Items:**
 - Collaborate with the business finance office to gather all security budget data.
 - Identify gaps and overlaps in funding.
 - Focus on IoT vendor risk management funding gaps.
- **Deliverables:**
 - Comprehensive report on security funding.
 - Gap analysis for IoT vendor risk management.
- **Timeline:** Completion by Q1 2025.
- **Status:** In Progress.

B. Security Culture Improvement

Objective

To enhance PowerTools Corporation's security culture by fostering stakeholder engagement, improving communication practices, and increasing awareness and training for all organizational levels.

Goals and Deliverables

1. Continuously Maintain the Stakeholder Engagement Table

- **Action Items:**
 - Regularly update the stakeholder engagement table as part of ongoing team projects.
 - Focus on maintaining active engagement with IoT maintenance teams and vendors.
- **Deliverables:**
 - Up-to-date stakeholder engagement table.
 - Documented interaction records with IoT maintenance teams and vendors.
- **Timeline:** Ongoing, with quarterly reviews starting January 2025.
- **Status:** Ongoing.

2. Improve Personal Communication Practices

- **Action Items:**
 - Assess and refine personal communication style to enhance clarity.
 - Focus on delivering precise and actionable updates to product teams regarding patching and other critical updates.
- **Deliverables:**
 - Improved communication process documentation.
 - Feedback from product teams on communication effectiveness.
- **Timeline:** Completion by Q2 2025.
- **Status:** In Progress.

3. Enhance Team Communication Practices

- **Action Items:**
 - Organize workshops for the security team to evaluate and improve group communication styles.
 - Facilitate cross-functional collaboration on security projects.
- **Deliverables:**
 - Workshop agendas and participation records.
 - Documented improvements in team communication practices.
- **Timeline:** Workshops to begin by Q1 2025, with progress review in Q3 2025.
- **Status:** Planned.

4. Develop User Awareness and Training Practices

- **Action Items:**
 - Task key team members to collect feedback from 1-3 IT stakeholders on the effectiveness of security-related communications.

- Create a feedback loop to incorporate stakeholder suggestions into user awareness campaigns.
- **Deliverables:**
 - Collected feedback and analysis report.
 - Enhanced user awareness training materials based on feedback.
- **Timeline:** Feedback collection to start by February 2025, with training updates completed by Q4 2025.
- **Status:** Planned.

C. Risk Management Improvement Business Plan

Objective

To strengthen PowerTools Corporation's risk management program by improving asset inventory processes, enhancing accountability for risk ownership, and aligning information risks with enterprise risk scenarios.

Goals and Deliverables

1. Review the Organization's Asset Inventory Program

- **Action Items:**
 - Assess the current asset inventory program for completeness and accuracy.
 - Identify an IT champion to collaborate with the risk management function.
 - Develop a method to capture asset risk scores and risk metadata as described in Section 4.2.
- **Deliverables:**
 - Comprehensive review of the asset inventory program.
 - Identification of an IT champion.
 - Documented process for capturing asset risk scores and metadata.
- **Timeline:** Completion by Q3 2025.
- **Status:** Planned.

2. Engage with Executive Stakeholders on Risk Reporting

- **Action Items:**
 - Meet with executive stakeholders responsible for reporting risk to the Audit Committee or other risk management forums.
 - Identify or discuss:
 - Accountable risk owners for categories of information risks.
 - Potential overlaps between information risks and top enterprise risk scenarios.
- **Deliverables:**
 - List of accountable risk owners.
 - Identification of overlaps between information and enterprise risks.
 - Recommendations for addressing identified overlaps.
- **Timeline:** Completion by Q2 2025.
- **Status:** In Progress.

D. Risk Management Improvement

Objective

To strengthen PowerTools Corporation's risk management program by improving asset inventory processes, enhancing accountability for risk ownership, and aligning information risks with enterprise risk scenarios.

Goals and Deliverables

1. Review the Organization's Asset Inventory Program

- **Action Items:**
 - Assess the current asset inventory program for completeness and accuracy.
 - Identify an IT champion to collaborate with the risk management function.
 - Develop a method to capture asset risk scores and risk metadata as described in Section 4.2.
- **Deliverables:**
 - Comprehensive review of the asset inventory program.
 - Identification of an IT champion.
 - Documented process for capturing asset risk scores and metadata.
- **Timeline:** Completion by Q3 2025.
- **Status:** Planned.

2. Engage with Executive Stakeholders on Risk Reporting

- **Action Items:**
 - Meet with executive stakeholders responsible for reporting risk to the Audit Committee or other risk management forums.
 - Identify or discuss:
 - Accountable risk owners for categories of information risks.
 - Potential overlaps between information risks and top enterprise risk scenarios.
- **Deliverables:**
 - List of accountable risk owners.
 - Identification of overlaps between information and enterprise risks.
 - Recommendations for addressing identified overlaps.
- **Timeline:** Completion by Q2 2025.
- **Status:** In Progress.

E. Access Control Improvements simplifying and rationalizing IT & security

Objective:

To enhance the efficiency of security operations and streamline access control processes by consolidating endpoint security tools and standardizing Role-Based Access Control (RBAC) across PowerTools Corporation.

Goals and Deliverables:

1. Consolidate Endpoint Security Tools and IoT Monitoring Solutions

- **Action Items:**
 - Evaluate the existing endpoint security tools & IoT monitoring tools.
 - Identify overlapping functionalities and redundant tools.
 - Choose a consolidated set of tools that balance cost efficiency and ease of management.
- **Deliverables:**
 - Consolidation plan outlining tools to be retained, retired, or replaced.
 - Implementation roadmap for the transition to the consolidated solution.
- **Timeline:** Evaluation and planning to be completed by Q2 2025, with implementation by Q4 2025.
- **Status:** Planned.

2. Rationalize Access Control Processes

- **Action Items:**
 - Conduct a comprehensive review of access control processes in collaboration with the IAM team and IT stakeholders.
 - Standardize Role-Based Access Control (RBAC) policies across departments to ensure consistent and secure access management.
- **Deliverables:**
 - Unified RBAC policy document applicable to all departments.
 - Training and guidance materials for employees on updated access controls.
- **Timeline:** Review to be completed by Q1 2025, with full standardization by Q3 2025.
- **Status:** In Progress.

F. Control Access with Minimal Drag on the Business

Objective:

To streamline access control processes and enhance security compliance by implementing Single Sign-On (SSO) for all employees and automating access reviews for critical systems minimizing the drag for business by eliminating the need of signing in individually on each platform.

Goals and Deliverables:

1. Implement Single Sign-On (SSO) for All Employees

- **Action Items:**
 - Identify and evaluate vendors to provide an SSO solution that integrates seamlessly with existing systems and supports IoT devices.
 - Develop a phased rollout plan to implement SSO across the organization.
 - Provide training and support for employees during the transition.
- **Deliverables:**
 - Vendor selection report and contract.
 - Phased SSO implementation roadmap.
 - Training materials and support resources for employees.
- **Timeline:** Vendor selection by Q1 2025, with rollout beginning Q2 2025 and full implementation by Q4 2025.
- **Status:** In Progress.

2. Automate Access Reviews for Critical Systems and IoT Telemetry

- **Action Items:**
 - Identify critical systems and IoT telemetry requiring access reviews.
 - Select or develop tools to automate access review processes.
 - Integrate automation tools with existing systems for seamless operation.
- **Deliverables:**
 - Detailed list of critical systems and IoT telemetry requiring access reviews.
 - Implementation plan for access review automation tools.
 - Documentation of automated workflows and training materials for relevant staff.
- **Timeline:** Planning and tool selection by Q2 2025, with implementation completed by Q4 2025.
- **Status:** Planned.

G. Resilience through Detection, Response, and Recovery

Objective:

To strengthen PowerTools Corporation's resilience by deploying a tailored Security Information and Event Management (SIEM) solution and conducting tabletop exercises to enhance preparedness for ransomware and firmware-based attacks.

Goals and Deliverables:

1. Deploy a Security Information and Event Management (SIEM) Solution

- **Action Items:**
 - Evaluate and compare SIEM solutions that are compatible with the existing IT infrastructure and optimized for IoT and cloud environments.
 - Design and implement a SIEM deployment strategy to ensure seamless integration.
 - Develop training programs for the security team to maximize SIEM efficiency.
- **Deliverables:**
 - Vendor evaluation report and selection.
 - Detailed SIEM deployment and integration plan.
 - SIEM user manual and training materials for the security team.
- **Timeline:** Vendor evaluation and selection by Q2 2025, with deployment completed by Q4 2025.
- **Status:** Planned.

2. Conduct Tabletop Exercises for Ransomware and Firmware-Based Attack Scenarios

- **Action Items:**
 - Plan and execute tabletop exercises focusing on IoT devices and ransomware or firmware-based attack scenarios.
 - Include cross-functional teams such as IT, R&D, operations, and legal to ensure a comprehensive approach.
 - Review and refine incident response and recovery protocols based on exercise outcomes.
- **Deliverables:**
 - Exercise schedule and agenda.
 - Incident response improvement recommendations.
 - Updated response protocols incorporating lessons learned.
- **Timeline:** First exercise scheduled for Q1 2025, with refinement and follow-ups through Q3 2025.
- **Status:** In Progress.

Risk Assessment Results

This section presents a security risk assessment for selected PowerTools Corporation information assets, identifying key risks, vulnerabilities, and areas of improvement. The assessment integrates findings from improvement objectives across security governance, culture, and resilience.

Identified Risks and Gaps

Risk Category	Description	Impact	Likelihood
IoT Security	Weak access control, lack of centralized IoT monitoring.	High	High
Endpoint Security	Inconsistent patch management.	Medium	High
Access Control	Lack of standardized RBAC policies across departments & SSO not fully deployed.	High	Medium
Vendor Management	Gaps in assessing third-party vendor risk, particularly for IoT-related vendors.	Medium	Medium
Incident Response	Delayed incident resolution & no tabletop exercises for response protocols.	High	Medium

Prioritized Risk Mitigation Actions

Mitigation actions are informed by the objectives listed in the improvement plans.

- 1. Enhance IoT Security**
 - Conduct monthly IoT security updates with stakeholders.
 - Implement a SIEM solution tailored for IoT environments.
 - Conduct tabletop exercises for ransomware and firmware attack scenarios.
- 2. Strengthen Endpoint Security**
 - Consolidate endpoint tools to simplify operations and enhance monitoring.
 - Automate patch management processes.
- 3. Standardize Access Control**
 - Implement Single Sign-On (SSO) across all systems.
 - Rationalize access control by standardizing RBAC policies across departments.
- 4. Improve Cloud Security**
 - Evaluate existing control baselines for alignment with 20 security control domains.
 - Perform a rapid enterprise risk assessment to identify top cloud-related risks.
- 5. Vendor Risk Management**
 - Work with the finance office to identify gaps in vendor security budgets.
 - Include vendor risks in regular security updates and charter revisions.
- 6. Incident Detection and Response**
 - Deploy an IoT-compatible SIEM system.
 - Conduct cross-functional workshops to refine incident response protocols.

Summary of Findings

PowerTools Corporation's security risk assessment highlights key vulnerabilities and areas for improvement across governance, culture, risk management, access control, and resilience. The findings underscore the need to strengthen IoT security, streamline endpoint and access management, and enhance incident detection and response capabilities.

Classification Scheme

An inventory of PowerTools Corporation's assets

1. Asset Inventory

Objective: Inventory and identify critical assets, such as applications, servers, or databases, and their respective system or data owners.

Asset Type	Examples	Criticality	System/Data Owner	Notes
Applications	ERP systems, CRM software	High	IT Applications Manager	Mission-critical; real-time availability is essential.
Servers	Database servers, application servers	High	Infrastructure Team Lead	Store and process confidential and proprietary data.
Databases	Customer information, IoT telemetry	High	Database Administrator	Contains sensitive personal or trade data; encryption is mandatory.
IoT Devices	Manufacturing sensors, trackers	High	IoT Maintenance Manager	Real-time operational dependency; tampering risks high.
Cloud Services	SaaS applications, storage solutions	High	Cloud Operations Manager	Holds proprietary data; shared responsibility for security.

2. Information Classification

Objective: Categorize data (e.g., public, proprietary, confidential, restricted) and identify types of sensitive data like personal information or trade secrets.

Data Category	Examples	Classification Level	Notes
Public Data	Marketing materials, press releases	Low	Freely accessible; minimal risk if exposed.
Proprietary Data	Product designs, internal reports	Medium	Internal access only; requires limited encryption.
Confidential Data	Financial records, IoT firmware	High	Must be encrypted and access restricted to authorized users.
Restricted Data	Customer PII, trade secrets	Very High	Subject to strict regulatory compliance; multi-factor access controls.

Asset Inventory

The table below summarizes the list of assets in the organisation, excluding the IoT devices.

Asset Type	OS Versions	Number	Criticality
Workstations - Windows	Windows 10	620	High
Workstations - Linux	Ubuntu 16	150	Medium
Workstations - Macs	Sequoia	300	Medium
Servers - Windows	Windows Server 2022	15	High
Servers - Windows	Windows Server 2019	20	High
Servers - Windows	Windows Server 2016	10	Medium
Servers - Windows	Windows Server 2012	80	Low
Servers - Windows	Windows Server 2008	5	Low

Security Impact Analysis

The following table depicts a sample security impact analysis of critical risks identified for PowerTools Corporation's security posture. Each category is assessed based on its description, impact level, likelihood.

Risk Category	Description	Impact	Likelihood
IoT Security	Weak access control, lack of centralized IoT monitoring.	High	High
Endpoint Security	Inconsistent patch management.	Medium	High
Access Control	Lack of standardized RBAC policies & incomplete SSO deployment.	High	Medium
Vendor Management	Gaps in assessing third-party vendor risks, especially IoT-related.	Medium	Medium
Incident Response	Delayed resolution & no tabletop exercises for protocols.	High	Medium

Threat Exposure (Risk) Ratings

Immediate attention is required to address weak access controls and monitoring in IoT systems, delayed incident resolution, and inconsistent access management policies. While **endpoint security** and **vendor management** exhibit slightly lower criticality, they still demand prompt action to mitigate potential disruptions. By prioritizing these risks based on their severity, the organization can focus resources effectively to enhance its overall security resilience.

Evaluation of Existing Safeguards and Residual Risk Ratings

The evaluation of existing safeguards reveals several areas where improvements are necessary to reduce residual risks effectively. While some safeguards, such as basic patch management and partial SSO deployment, provide moderate protection, gaps in **IoT monitoring**, **vendor management**, and **incident response preparedness** maintain high residual risks. Strengthening these safeguards through automation, standardization, and enhanced testing is essential to mitigate vulnerabilities and align the security framework with organizational objectives.

Detailed Findings

Below are the detailed findings

1. IoT Security

- Existing Safeguards:
 - Limited network segmentation for IoT devices.
 - Manual monitoring of some IoT devices.
- Effectiveness:
 - Low, the lack of centralized IoT monitoring and robust access controls significantly limits the organization's ability to detect and respond to IoT-related threats.
- Residual Risk Rating:
 - High
- Details:
 - Without centralized monitoring or advanced security controls, IoT devices remain exposed to unauthorized access and potential exploitation. This poses a critical risk to operational continuity and data integrity.

2. Endpoint Security

- Existing Safeguards:
 - Basic patch management processes.
 - Occasional manual updates performed by IT staff.
- Effectiveness:
 - Moderate, while some patches are applied, the inconsistent application leaves endpoints vulnerable to known exploits.
- Residual Risk Rating:
 - Medium
- Details:
 - Endpoints are susceptible to malware and other cyber threats due to delayed or missed updates. Strengthening automation and policy enforcement can significantly improve risk mitigation.

3. Access Control

- Existing Safeguards:
 - Partial implementation of Single Sign-On (SSO).
 - Basic Role-Based Access Control (RBAC) policies in some departments.
- Effectiveness:
 - Moderate, SSO is incomplete, and non-standardized RBAC policies create inconsistencies and potential security gaps.
- Residual Risk Rating:
 - Medium
- Details:
 - Incomplete SSO rollout and department-specific RBAC practices prevent efficient access management and increase the risk of unauthorized access.

4. Incident Response

- Existing Safeguards:
 - Basic incident response plan.
 - Limited practice through tabletop exercises.
- Effectiveness:
 - Low, the lack of robust testing and refinement reduces the response team's ability to manage high-impact incidents effectively.
- Residual Risk Rating:
 - Medium
- Details:
 - Delayed incident response and minimal hands-on practice leave the organization ill-prepared for ransomware or firmware-based attack scenarios.

Risk Treatment Strategy

Assets owners and executives at PowerTools Corporation maintain the ability to manage risks using one of the four risk management strategies:

1. Risk Avoidance

Eliminate the risk entirely by discontinuing activities or services that generate the risk.

2. Risk Mitigation

Reduce the likelihood or impact of a risk by implementing controls, safeguards, or processes.

3. Risk Transfer

Shift the financial or operational burden of a risk to a third party, such as through insurance or outsourcing.

4. Risk Acceptance

Acknowledge the risk and choose not to take further action, typically when the cost of mitigation outweighs the benefits.

Maintaining the Risk Register

This section outlines the framework for maintaining an up-to-date and effective risk register at PowerTools Corporation. A well-maintained risk register ensures that all identified risks are tracked, assessed, and managed appropriately, fostering a proactive approach to risk management.

Concluding Remarks

This Cybersecurity Business Plan was authored by the Director of Cybersecurity at PowerTools Corporation with the goal of creating a structured, actionable, and forward-looking approach to managing the organization's security risks.

The strategies outlined in this plan aim to:

- Enhance Security Governance: By fostering strong communication between the CISO, security teams, and stakeholders, and aligning security objectives with business priorities.
- Build a Resilient Security Culture: Through improved communication practices, increased awareness, and continuous engagement across all levels of the organization.
- Optimize Risk Management: By aligning risk management strategies with business objectives, establishing a control baseline, and leveraging advanced tools and methodologies.
- Simplify and Rationalize IT & Security Operations: Ensuring efficient use of resources while maintaining a robust security posture.
- Institute Resilience through detection, incidence & response: Through proactive detection, response, and recovery mechanisms that address current and emerging threats.

Document History

December	Draft Submitted by
December	Approved by CISO
December	Approved by CEO
December	Document Published

References

1. Rational Cybersecurity for Business – Dan Blum
2. Advanced Persistent Security – Ira Winkler

List of Attachments

1. Success Plan Worksheet